

# Evaluación de exposición del servidor de archivos

My File Server 1 · Compromiso de privilegio total confirmado

---

Riesgo residual: crítico

Clasificación: confidencial

Audiencia: Consejo Directivo

# Por qué se evaluó este sistema

## Objetivo

Medir la exposición real de un servidor de archivos que concentra documentos de la operación.

## Rol

Analista Red Team contratado por la organización. Prueba autorizada, en laboratorio controlado.

## Alcance

Un host: 10.0.2.4. Servicios de archivo, web y acceso remoto. Sin terceros ni usuarios reales.

## Criterio de éxito

Determinar si un atacante externo puede leer, modificar o controlar la información del servidor.

# Cuatro fases, un solo hilo de ataque

**01**

## Reconocimiento

Identificación del host en el segmento y de los servicios publicados.

**02**

## Enumeración

FTP, web y registros. Se obtuvo un usuario válido y una contraseña en claro.

**03**

## Explotación

Acceso remoto como usuario de negocio, sin adivinar contraseñas en el acceso final.

**04**

## Escalada

El sistema operativo, sin parches, permitió pasar de usuario a administrador.

# El servidor puede quedar bajo control ajeno

## CRÍTICO

Privilegio de administrador confirmado sobre el host que custodia los archivos.

No es un hallazgo teórico.  
La prueba llegó hasta el archivo de evidencia en el directorio de root.

### Confidencialidad

Comprometida

Lectura de registros, cuentas y archivos de administración.

### Integridad

Comprometida

Se alteró la autenticación y un binario del sistema.

### Disponibilidad

En riesgo

Quien controla el host puede detener el servicio de archivos.

## Cuatro fallas encadenadas, no un incidente aislado

| ID   | Hallazgo                                          | Severidad | Efecto para el negocio              |
|------|---------------------------------------------------|-----------|-------------------------------------|
| H-01 | Acceso anónimo al servicio de archivos            | Media     | Revela usuarios y registros         |
| H-02 | Contraseña publicada en la web interna            | Alta      | Abre la cuenta de negocio           |
| H-03 | La cuenta puede modificar su propio acceso remoto | Alta      | Entrada persistente sin contraseña  |
| H-04 | Sistema operativo sin parche de 2016              | Crítica   | De usuario a administrador del host |

# Qué significaría esto en operación

Un atacante no necesita vulnerar a cada usuario. Con un archivo mal publicado y un sistema sin actualizar, toma el servidor que guarda los documentos de la empresa.

## Datos

Contratos, respaldos y archivos compartidos quedan legibles y copiables.

## Confianza

La cuenta de servicio deja de ser confiable. El acceso puede persistir.

## Operación

El servicio de archivos puede detenerse o alterarse sin pasar por un administrador.

## Responsabilidad

Un incidente de este tipo activa deberes de aviso, investigación y remediación.

# Probabilidad alta, impacto alto

|                    | Impacto bajo | Impacto medio           | Impacto alto   |
|--------------------|--------------|-------------------------|----------------|
| Probabilidad alta  |              | H-01 Acceso anónimo     | H-02 H-03 H-04 |
| Probabilidad media |              | H-05 Servicios antiguos |                |
| Probabilidad baja  |              |                         |                |

H-04 concentra el riesgo: es probable en este estado de parches y el daño es la pérdida del host.

# Tres decisiones, no una lista de herramientas

1

## Cerrar la exposición pública de credenciales

Retirar archivos con contraseñas, rotar la cuenta afectada y deshabilitar el acceso anónimo al repositorio de archivos.

2

## Recuperar el control del host

Aplicar el parche del sistema operativo, restaurar binarios alterados y revocar llaves de acceso no autorizadas.

3

## Evitar que se repita

Reducir servicios abiertos, separar el servidor de archivos y establecer un ciclo formal de actualización.

## 30, 90 y 180 días

30 días

### Contener

Retirar el archivo con la contraseña.  
Rotar credenciales.  
Cerrar FTP anónimo.  
Revocar llaves SSH ajenas.  
Parchear el kernel.

90 días

### Corregir

Minimizar servicios abiertos.  
Separar el servidor de archivos.  
Revisar permisos de escritura.  
Alertar creación de accesos remotos.

180 días

### Sostener

Ciclo de parcheo con dueño.  
Prueba de restauración.  
Métrica de servicios expuestos.  
Reevaluación del mismo escenario.

# El servidor de archivos no está bajo control de la organización.

|                       |                                                                                        |
|-----------------------|----------------------------------------------------------------------------------------|
| <b>Decisión</b>       | Tratar el host como comprometido hasta parchear, rotar accesos y restaurar binarios.   |
| <b>Prioridad</b>      | La contraseña publicada y el sistema sin actualizar son la causa, no un síntoma menor. |
| <b>Siguiente paso</b> | Autorizar el plan de 30 días y nombrar un dueño de la remediación.                     |